

EVENT WORKSPACE

VSMS event operations, reporting & public page

Implementation report • 4 August 2026

OUTCOME

A complete, no-sidebar event workspace shaped around physical venue operations.

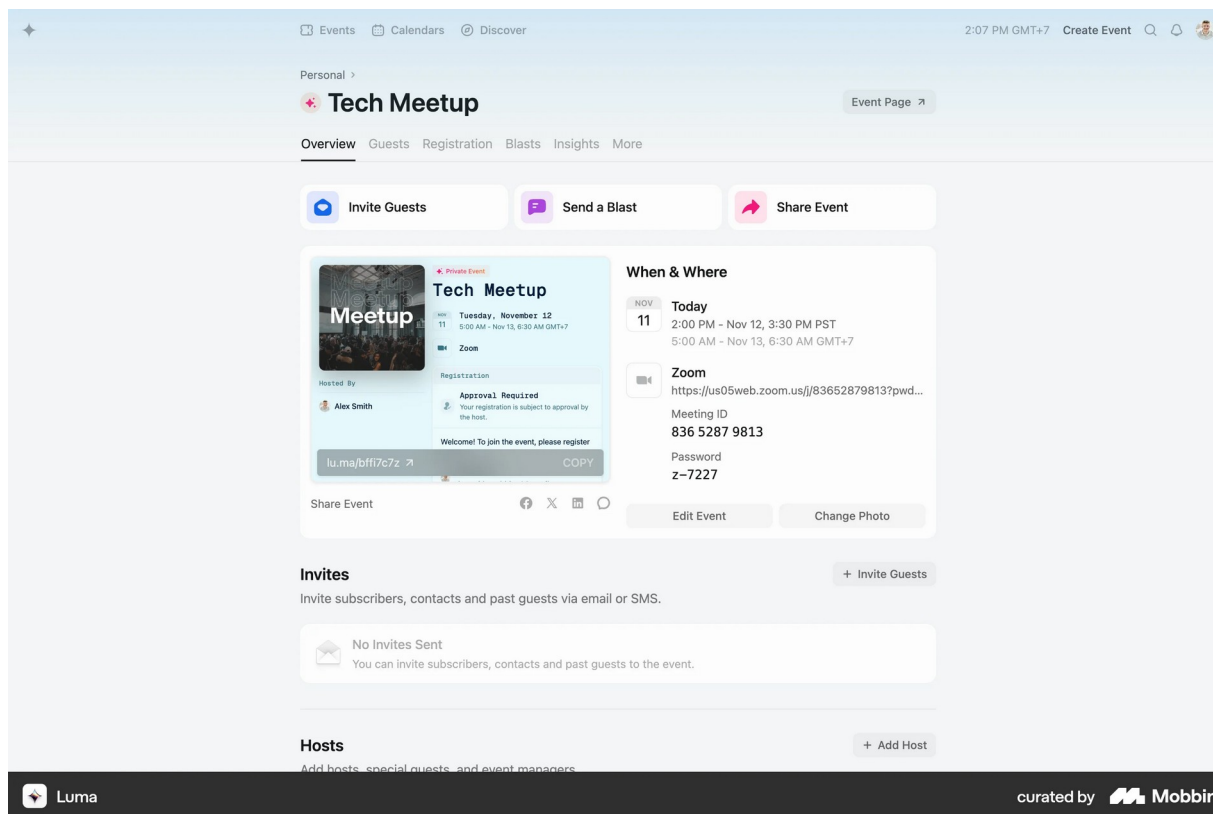
It combines Luma-inspired hierarchy with VSMS station availability, manpower planning, signups and attendance reporting, a safe public event landing page, and export-gated draft deletion.

Delivery	Result
Working branch	nachiketh/eventsandmore — no new branch
Source control	Changes left unstaged and uncommitted, as requested
Infrastructure	Cloud-ready application changes only; no AWS or other deployment
Validation	Schema, OpenAPI, generated contract, lint, build, 33 backend tests, 28 static checks, queue regression, dependency audit, responsive browser QA

REFERENCE → VSMS

Design translation

The Luma reference supplied the hierarchy: concise navigation, event identity, tabbed workspace, overview actions, and a clear when-and-where summary. VSMS keeps that calm layering while replacing video-meeting language and guest-marketing patterns with physical venue operations.



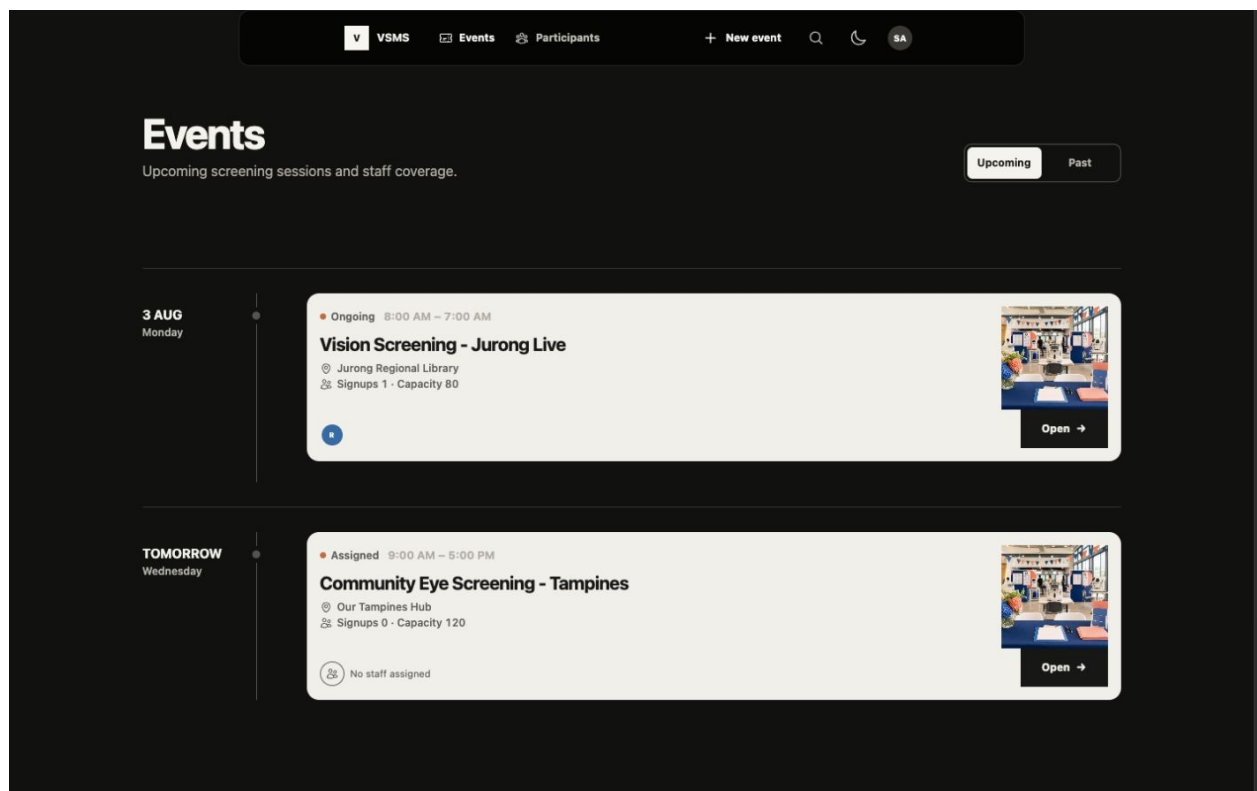
Supplied Luma reference used for hierarchy and layering only.

- Removed the global sidebar and its toggle; the product now uses a responsive 64px command bar.
- Physical venue, station order, availability slots, shifts, and assigned people are first-class facts.
- Warm operational canvas + near-black records + restrained orange status signal; no gradients, glass, glow, or generic bento styling.

OPERATIONAL OVERVIEW

Event register

The index is a chronological run sheet. Each event remains information-dense without becoming a dashboard mosaic: date rail, status, venue, signups, capacity, owner, and a direct 44px action.



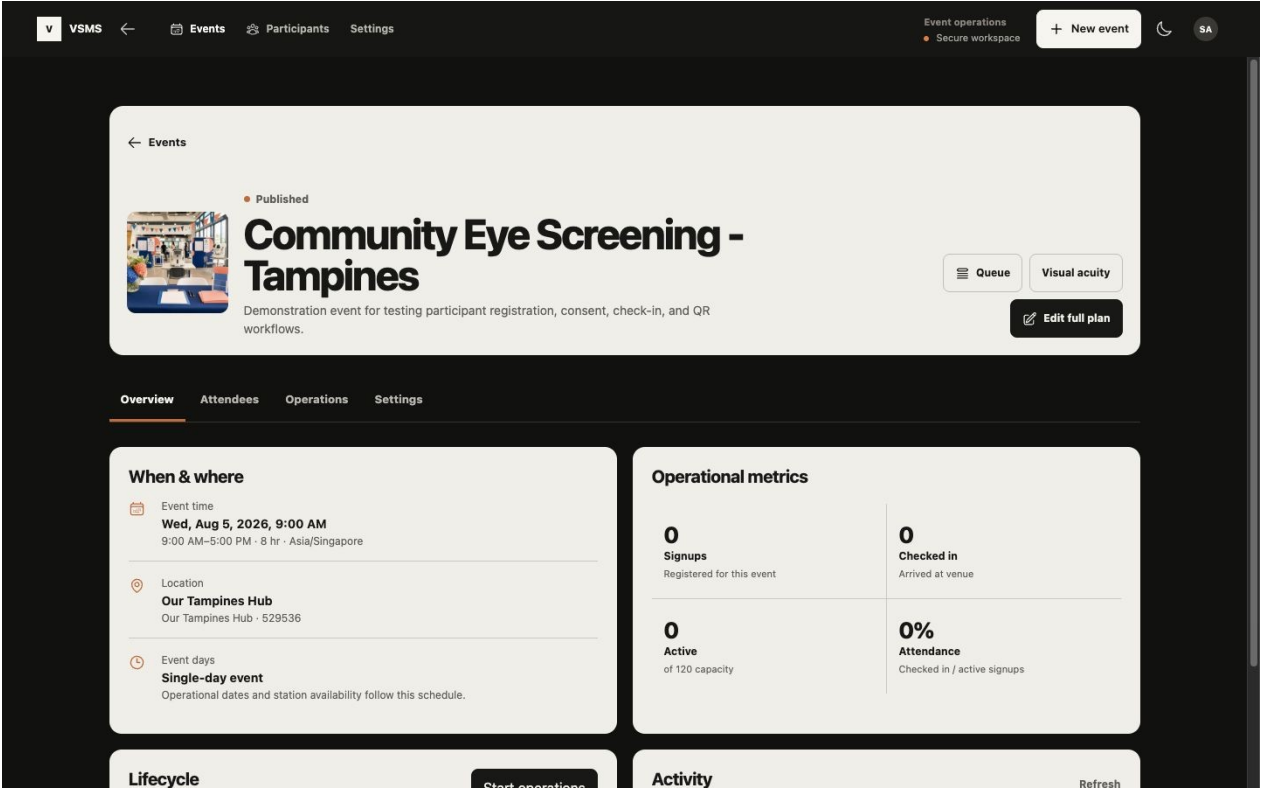
Desktop event register — chronological rail, compact physical-venue facts, truthful signup/capacity labels.

Pagination is consumed completely with a repeated-cursor guard, so search and upcoming/past filtering do not silently stop at the first page. The list intentionally says “Signups” rather than presenting active capacity as attendance.

PLAN AND OPERATE

Event workspace

The authenticated workspace keeps event identity and primary actions stable while its tabs separate overview, attendees, operations, and settings.

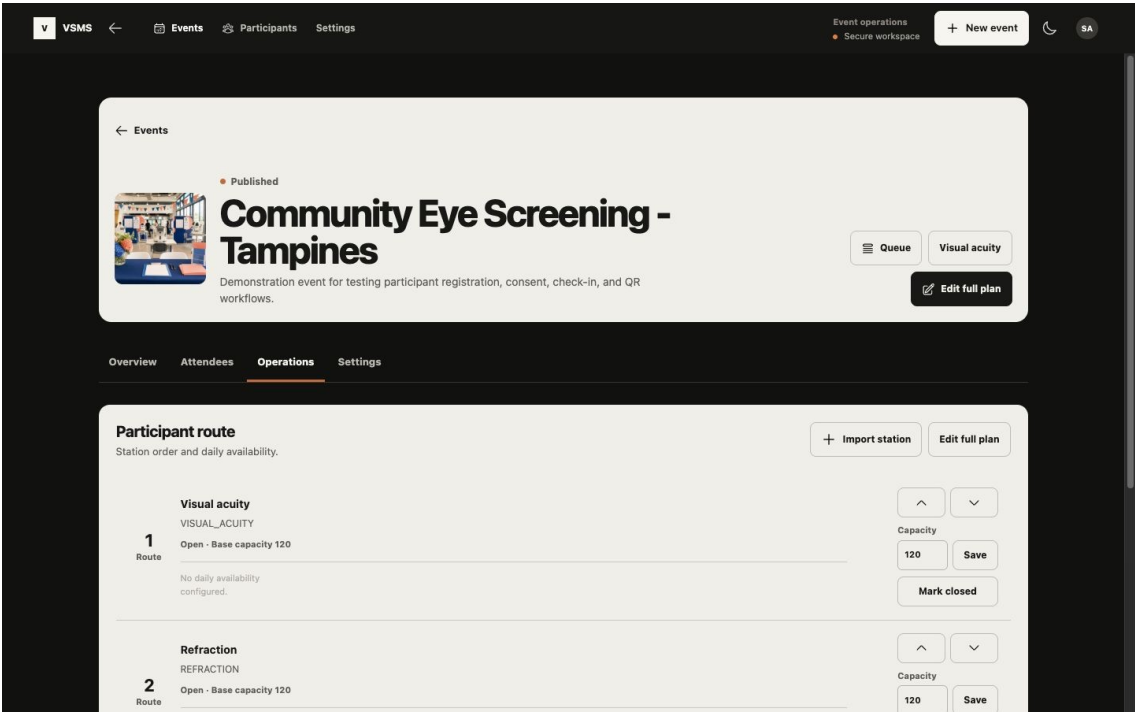


Overview — event identity, real location and schedule, metrics, lifecycle, and audit context.

OPERATIONS

Station and manpower plan

The operational view exposes the event’s real execution plan without inventing coverage: ordered stations, day/time availability, capacity, shifts, named assignments, and an aggregate manpower summary of filled positions, open positions, fully staffed shifts, and active placements.

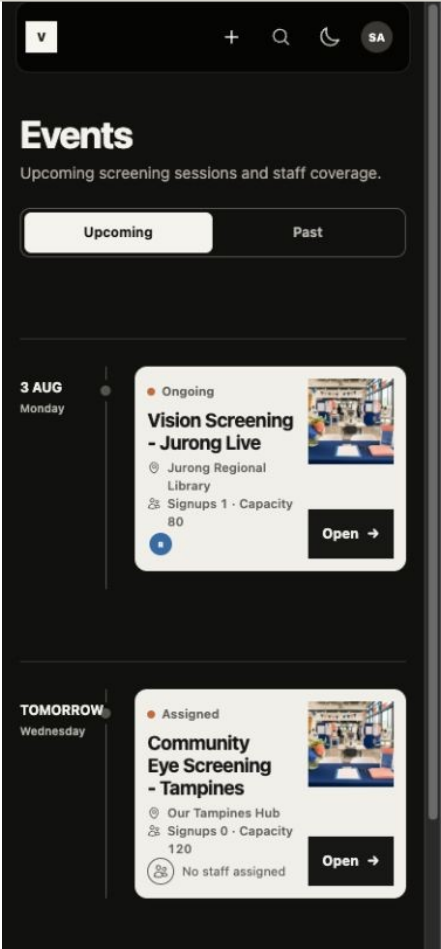
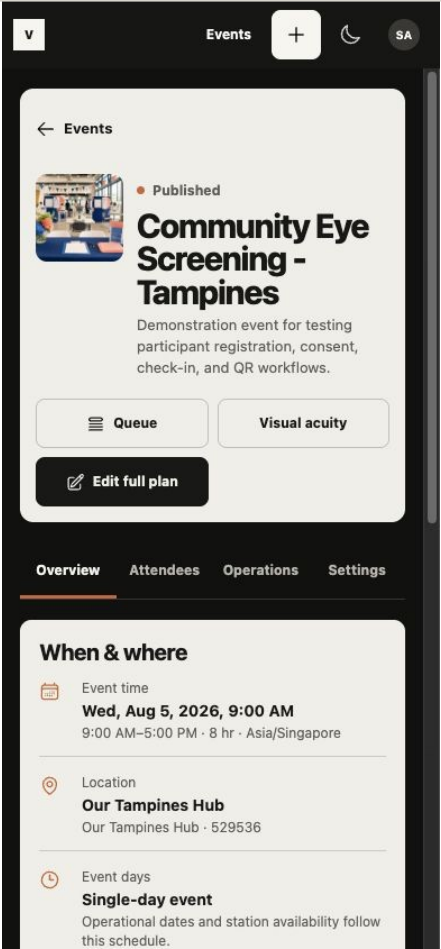


Operations — ordered stations, day/time availability, capacity, shifts, and factual manpower assignments.

MOBILE EVIDENCE

Responsive operation

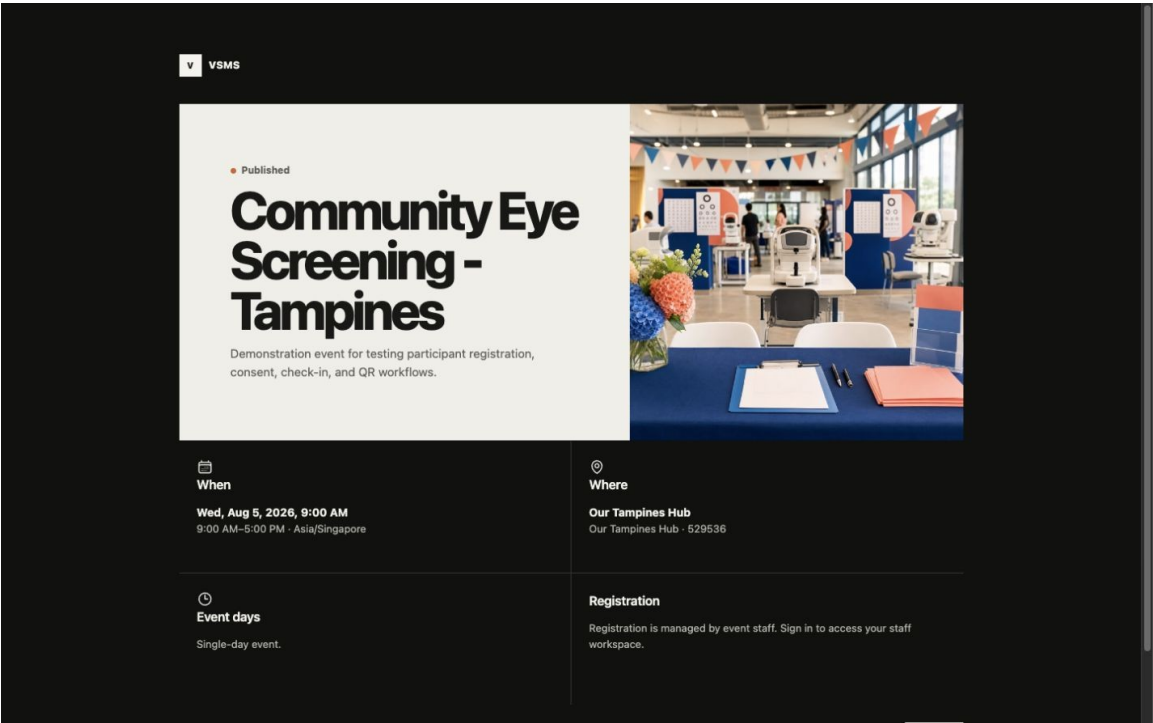
At phone widths the chronology rail, useful metadata, tab set, and primary actions remain intact. Labels condense before touch targets do; workspace tabs remain keyboard-operable and fit without page-level horizontal overflow.

	
Event list	Event workspace
Accessibility baseline	Implementation
Targets	44px routine actions; 48px tabs and navigation controls
Keyboard & semantics	Visible focus; route-specific browser titles; ArrowLeft/ArrowRight/Home/End tabs; announced loading state; captioned attendee table with scoped columns
Motion	Transitions disabled when reduced motion is requested
Layout	No page-level horizontal overflow at tested phone and desktop viewports

SAFE BY DESIGN

Public event landing page

The public page is a read-only venue briefing, available outside authentication only for non-draft events. It contains the event identity, physical location, dates, schedule, capacity, and status—never attendees, staff assignments, audit records, clinical data, or online-meeting details.

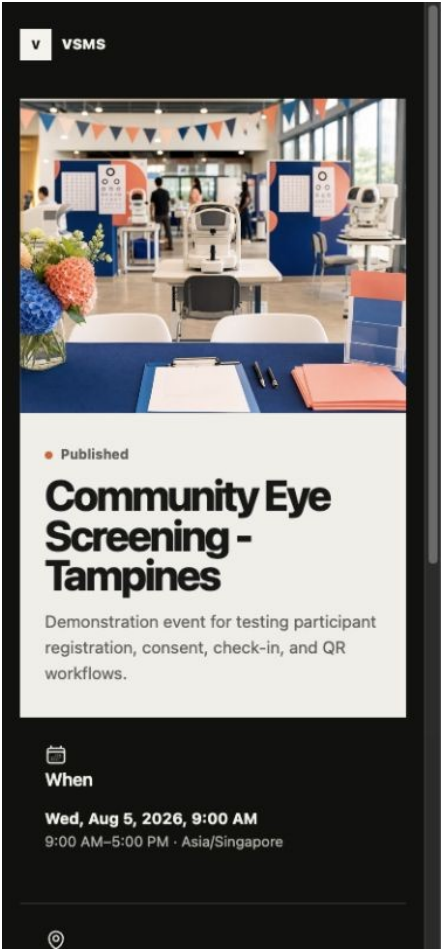


Desktop public event page — physical venue briefing and schedule.

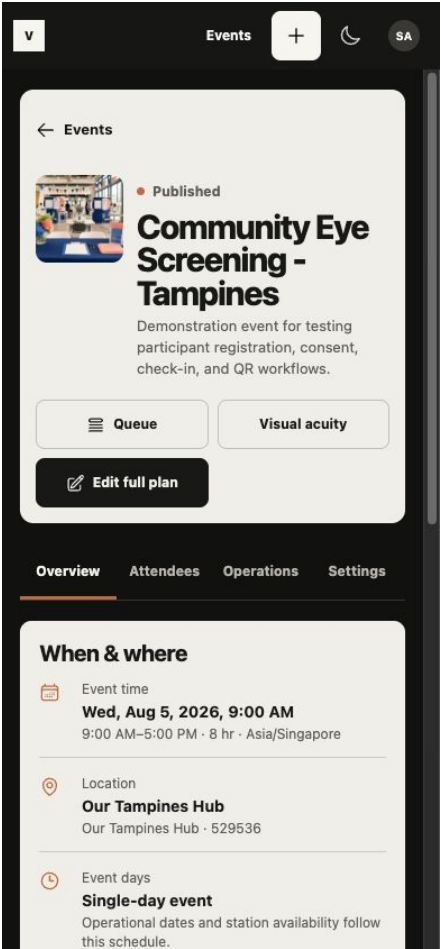
MOBILE EVIDENCE

Public and staff views

The public briefing and authenticated workspace retain distinct data boundaries at the same phone width.



Mobile public page



Authenticated workspace

FEATURE MAP

Implemented product surface

Area	Delivered behavior
Shell & settings	No sidebar; responsive command bar; theme, profile, command palette, and settings retained.
Overview	Venue, schedule, event days, truthful signups/check-ins/attendance, lifecycle, and audit context.
Attendees	Authenticated search and status filter with signed cursor pagination, 50-row loads, and explicit loading/error/empty states.
Operations	Ordered stations, per-day availability, shifts, assigned people/roles, and truthful aggregate manpower coverage.
Settings	Edit link, lifecycle controls, cancellation, export, and guarded draft deletion in one workspace.
Public landing	Read-only public projection for non-draft events, surfaced as a first-class event action.
API contract	Canonical metrics, attendees, export, delete, public event, GET, and PATCH paths documented and generated.

Files and boundaries

Frontend changes live in the existing React application shell and event feature. Backend changes reuse the existing Express, Zod, Prisma, OpenAPI, rate-limit, authentication, and authorization patterns. No new dependency or speculative platform abstraction was added.

Teammate-owned station import/configuration, participant, QR, screening, and registration implementations were not replaced. The station/manpower planning UX remains visible for review, while three persistence operations fail explicitly with documented 501 responses until the teammate-owned station model work lands.

HIGH-IMPACT CONTROLS

Security and deletion model

Boundary	Control
Public read	UUID validation; 120 requests/minute; narrow projection; drafts use the same 404 as unknown IDs; cache max 60 seconds.
Private reporting	Authenticated; manager/admin authority; no-store; 60 requests/minute per user; attendee pages capped at 100.
Export	Versioned JSON with event, aggregate metrics, days, availability, stations, shifts, essential staffing fields, and narrow attendee rows; free-form assignment notes are excluded.
Receipt	Domain-separated HMAC-SHA256; base64url; 15-minute expiry; binds event, version, actor, and stable export hash.
Delete	Serializable transaction; exact event name/version/receipt; only an unpopulated DRAFT with zero registrations and consents.
Retention	Global users, participants, station templates, and event audit rows are preserved; a general audit tombstone records deletion.

Session and provider hardening

Risk	Implemented control
Browser credentials	Cognito access and refresh tokens remain Secure + HttpOnly; no credential token is exposed to JavaScript.
CSRF	Rotating double-submit token, allowed-Origin check, Fetch Metadata check, and protection on cookie-authenticated mutations.
Compatibility	Existing signed Bearer-token API clients remain supported without weakening the browser cookie path.
Key rotation	Unknown Cognito signing-key IDs trigger one immediate JWKS refresh; JWKS fetches time out after five seconds.
Provider stalls	Cognito token and account requests time out after ten seconds instead of holding API requests indefinitely.
Stale browser state	Without the authoritative session/CSRF cookie, cached profile state is cleared instead of presenting a false authenticated session.
Blocked Web Storage	Session state fails closed; device identification uses an in-memory UUID fallback rather than breaking requests.

Risk	Implemented control
Return path	Post-login redirects reject external, protocol-relative, backslash, encoded-control, and malformed paths.

Why deletion is deliberately narrow

Populated or clinical events cannot be deleted; export alone does not make a purge safe. Only an empty DRAFT can be removed after a fresh receipt. The public page is read-only and rate-limited, so CAPTCHA is deferred until a public mutation exists.

4 AUGUST 2026

Continuation hardening

Finding	Resolution and direct impact
API startup crash	Removed unused imports introduced in Keefe's participant-QR merge, including undeclared js-yaml/Socket.IO references, and removed the undefined io export. The API now loads and listens normally.
Session mismatch	Completed the repository's documented HttpOnly Cognito-cookie + CSRF design. Previously the browser could not authenticate event calls and refresh sent invalid strict-JSON null.
Reload CSRF race	Mutation requests now recover the rotating CSRF token from its readable cookie when in-memory state has not hydrated after a page reload.
Local port collision	Aligned backend, example configuration, Vite proxy, and OpenAPI on 5050; avoids macOS Control Center's common port-5000 listener.
Setup drift	README, HTTPS smoke test, Bruno environment, and API collection now agree on managed Cognito login and the 5173/5050 local HTTPS surface.
Audit pagination	Uses timestamp plus record ID, so equal-timestamp audit rows are not skipped between signed-cursor pages.
Lifecycle regression	Corrected Keefe's merge-adjusted event commands from the legacy id field to the schema's eventId key, retained canManage in responses, and covered publish/cancel with executable tests.
Event plan integrity	Event creation persists selected event days; create/update reject day slots outside the overall schedule; simple physical-location edits no longer depend on an absent station model; unsupported station/staff-plan writes fail explicitly with 501.
Versioned staffing	Staff removal now validates the real assignment ID and atomically checks/increments the event version before deletion, preventing stale editors from overwriting each other.

Finding	Resolution and direct impact
Shared route pass	Event and screening endpoints now share one authentication and mutation-limit pass, eliminating duplicate user lookups and double-counted screening writes.
Scoped operations	Screening access is event-scoped for managers and station-scoped for screeners; clinical aggregates and full event-management actions require event-level management authority.
Privacy projection	Exports omit free-form assignment notes; ordinary assigned staff receive only roster user ID/display name and never contact, role-status metadata, or private notes.
Audit boundary	Event mutations retain real request ID, IP, and device context; malformed request/device IDs cannot reach PostgreSQL UUID columns.
Transport headers	Live API policy denies framing, camera, microphone, and geolocation; Swagger-only inline CSP allowances are development-only and smoke-tested.
Log and seed safety	Removed redundant raw validation logging; production blocks demonstration seeding and seed logs no longer publish the fixed demo QR pass token.
Storage reliability	Blocked Web Storage no longer crashes app startup, theme changes, session restoration, or device identification; sensitive state still fails closed.
Supply-chain claim	Removed two mismatched/unused runtime signature prototypes that could silently skip verification. Signed immutable artifacts remain an explicit deployment-pipeline requirement, not an unproved application claim.
Error disclosure	Unknown failures never expose raw messages. Existing bounded status hints retain correct 4xx/5xx semantics with generic copy; unclassified failures become generic 500 responses.
Role-consistent actions	The event register now exposes creation only to verified administrator/event-manager grants, matching the shell and backend instead of treating every non-staff role as privileged.
Theme interaction	Removed the nonessential native view-transition layer after it dropped rapid repeat clicks; each theme choice now applies immediately with the existing icon feedback.
Landing evidence	Replaced the preview placeholder with a real, PII-free workspace screenshot, truthful captions, and a connected-workflow claim instead of unsupported offline-sync copy.
Dependency exposure	Updated ip-address to 10.4.0 and removed unused Geist/Next/sharp graph. Backend production audit is clean.
Bundle size	Route-level lazy loading, including the authenticated shell and event register, reduced initial JavaScript from 818.37 kB to 294.47 kB — a 64.0% reduction and no size warning.

The frontend audit still reports the React Router RSC advisory GHSA-qwww-vcr4-c8h2. This Vite BrowserRouter application does not import or use the affected unstable RSC APIs, and the advisory's patched 8.3.0 release is not published in the installed package line. The non-reachable advisory is recorded rather than forcing an incompatible or nonexistent upgrade.

4 AUGUST 2026

Verification record

Gate	Outcome
Prisma schema	Valid
OpenAPI	Valid; four warnings: one existing auth redirect and three documented 501-only teammate stubs
Generated client	Matches canonical OpenAPI contract
Frontend lint	Passed
Production build	Passed; initial JavaScript 294.47 kB (96.38 kB gzip), no size warning
Backend unit/security tests	33/33 passed; includes event/station-scoped screening and clinical-metrics authorization
Static integration contracts	28/28 passed; includes role-consistent actions, reliable theme toggling, storage fallback, production seed guard, release-integrity claim, shared route-pass, CSRF, schema, and validation checks
Database integration	Guarded harness stopped before migrations: local vsms_dev_test is absent and the configured role cannot create databases; no cloud database was changed
Production dependency audit	Backend: 0 vulnerabilities. Frontend: two RSC-only React Router advisory instances, non-reachable here
Queue regression	1/1 passed
Impeccable detector	No findings
Browser QA	Desktop/mobile evidence retained; local landing and real product preview rendered without placeholder content; authenticated live QA is environment-gated
HTTPS smoke	Passed: trusted frontend/API, proxied private-route 401, plain HTTP rejection, anti-framing CSP, and device-permission denial
Whitespace	git diff --check passed

Known pre-existing / teammate-owned blockers

The wider event service still contains three documented station import/configuration/assignment 501 paths pending teammate PR #65. They were not replaced because that implementation remains teammate-owned and changing it here would collide with the active station model work.

The Sol Advisor native-agent preflight also reports two missing local template files: sol-advisor-terra-implementer.toml and sol-advisor-sol-reviewer.toml. The continuation therefore used bounded local verification rather than silently substituting another delegation path.

READY FOR REVIEW

Handoff

The requested MVP is implemented on the existing branch and left uncommitted. It can be reviewed locally using the captured desktop and mobile evidence in .codex/images. No cloud resource was created, restarted, or deployed.

Artifact	Location
Design system	/Users/nr/developer/react-nodejs-project2-cryptix/DESIGN.md
Implementation report	/Users/nr/developer/react-nodejs-project2-cryptix/.codex/ VSMS-Event-Workspace-Implementation-Report.docx
Screenshot evidence	/Users/nr/developer/react-nodejs-project2-cryptix/.codex/ images
Security note	/Users/nr/documents/Obsidian Vault/Secure Coding/wiki/vsms-event-workspace-security.md

Recommended next step: have a local database administrator create vsms_dev_test, rerun the guarded integration harness, then integrate the teammate-owned station 501 implementations before any deployment.